

MCCoE CYBERSECURITY APPRENTICESHIP PROGRAM

PROJECT 6 OF 8 — PART 2: FRAMEWORKS + EXECUTIVE SUMMARY
SOLARWINDS SUPPLY CHAIN ATTACK (2020)

Nation-State Attack · Supply Chain · 18,000 Victims · 9 Months Undetected

 **THIS PROJECT:** Apply the NIST CSF and pentesting methodology. Write and present your professional Executive Summary. This project ends with your Executive Summary submission (100 points).

PROJECT 6 · DAY 6

MONDAY — NIST CSF — DEFENSIVE FAILURE ANALYSIS

1-2 HRS

 **OBJECTIVE:** Students apply all 5 NIST Cybersecurity Framework functions to identify exactly what the organization did wrong and what they should have done.

PROJECT 6 · DAY 7

**TUESDAY — 5 PHASES OF PENTESTING — ATTACKER
METHODOLOGY**

1-2 HRS

 **OBJECTIVE:** Students map the attacker's actions to the 5 pentesting phases. Think like an attacker to become a better defender.

PROJECT 6 · DAY 8

**WEDNESDAY — RECOMMENDATIONS WORKSHOP —
"FROM HERE ON OUT"**

1-2 HRS

 **OBJECTIVE:** Students develop and workshop 5 specific, actionable recommendations. Peer collaboration to pressure-test each recommendation.

PROJECT 6 · DAY 9

**THURSDAY — EXECUTIVE SUMMARY PRESENTATIONS +
SUBMISSION (100 PTS DUE)**

1-2 HRS

 **OBJECTIVE:** Students complete peer review, deliver professional executive summary presentations, submit, and debrief the full incident.

"FROM HERE ON OUT" — RECOMMENDATIONS REFERENCE

🔗 **NOTE:** These are the controls that, if in place, would have prevented or significantly reduced this breach.

- **MANDATE:** Software Bill of Materials (SBOM) — every piece of software must declare all components it contains
- **MANDATE:** Zero Trust Architecture — even trusted software from known vendors must have limited, monitored access
- **MANDATE:** Behavioral monitoring — signature-based tools failed here; detect anomalous behavior, not known-bad signatures
- **IMPLEMENT:** Threat hunting program — proactively search for threats rather than waiting for alerts
- **IMPLEMENT:** DNS anomaly monitoring — SUNBURST used DNS for C2; unusual DNS patterns must trigger investigation
- **IMPLEMENT:** Third-party software access controls — monitoring tools should have limited network access even when they need visibility

REFERENCES & RESOURCES

- FireEye Blog: "Highly Evasive Attacker Leverages SolarWinds Supply Chain" (December 13, 2020) — [mandiant.com](https://www.mandiant.com)
- CISA Emergency Directive 21-01 — cisa.gov/emergency-directive-21-01
- nvd.nist.gov/vuln/detail/CVE-2020-10148 — full technical details
- U.S. Senate Intelligence Committee: SolarWinds Hearing (February 23, 2021)
- Executive Order 14028 on Improving the Nation's Cybersecurity — [whitehouse.gov](https://www.whitehouse.gov)
- MITRE ATT&CK: attack.mitre.org — search T1195, T1071, T1027